

PROTOCOLO CRIPTOGRÁFICO DE ALMACENAMIENTO Y DERECHOS ARCO

ENTIDAD: Neobank Digital, S.A.

MÓDULO 1: Política de Privacidad y Tratamiento de Datos

ENTREGABLE 1.3: Protocolo Criptográfico de Almacenamiento y Derechos ARCO (Documento 3 de 3)

VERSIÓN: 4.2.0-PROD

CLASIFICACIÓN: Estrictamente Confidencial / Secreto Corporativo

CAPÍTULO I: ARQUITECTURA CRIPTOGRÁFICA DEL TRÁNSITO Y PERÍMETRO DE RED

1.1. Seguridad de Canales en Capa de Transporte (TLS 1.3 y HSTS)

Neobank Digital, S.A. impone el uso exclusivo del protocolo Transport Layer Security (TLS 1.3) para la totalidad de las sesiones de comunicación de datos que se originen o terminen dentro de su infraestructura tecnológica orientada al usuario. Queda terminantemente prohibida la negociación a la baja (downgrade) hacia versiones TLS 1.2 o inferiores, denegando de manera automatizada las peticiones de clientes móviles o navegadores web que no cumplan con este requerimiento de seguridad. Los conjuntos de cifrado (Cipher Suites) autorizados se limitan estrictamente a TLS_AES_256_GCM_SHA384 y TLS_CHACHA20_POLY1305_SHA256, garantizando las propiedades técnicas de Secreto Perfecto hacia Adelante (Perfect Forward Secrecy) y resistencia ante ataques criptanalíticos avanzados.

Para asegurar que ningún vector de comunicación intente derivar el tráfico hacia canales no cifrados, las cabeceras de respuesta HTTP del API Gateway inyectan la directiva HTTP Strict Transport Security (HSTS) parametrizada de manera rígida: `Strict-Transport-Security: max-age=63072000; includeSubDomains; preload`. Adicionalmente, el ecosistema de red utiliza el mecanismo de Anclaje de Certificados (Certificate Pinning) embebido estáticamente en el código fuente de la aplicación móvil (iOS y Android), forzando al cliente móvil a validar que las llaves públicas presentadas durante el acuerdo de conexión correspondan exactamente con las firmas de la entidad de certificación raíz interna de la Entidad, mitigando de raíz cualquier ataque interceptor.

1.2. Protocolo de Aislamiento VPN e Interfaces de Conexión de Terceros

Las conexiones perimetrales destinadas al intercambio de información con redes externas autorizadas (tales como la adquirencia de Visa/Mastercard, la red ACH inmediata o las APIs del RENAP y la SAT) se encapsulan mediante túneles seguros basados en el protocolo IPsec (Internet Protocol Security). La fase de establecimiento del túnel exige autenticación robusta mediante certificados digitales X.509 de 4096 bits emitidos de manera exclusiva para cada canal de integración. Las llaves simétricas utilizadas para el cifrado del tráfico del túnel expiran e inician un proceso automático de renegociación efímera cada tres mil seiscientos (3,600) segundos bajo el algoritmo Diffie-Hellman en su Grupo 19 o superior.

CAPÍTULO II: CIFRADO AVANZADO EN REPOSO E INFRAESTRUCTURA HSM

2.1. Cifrado de Transparencia (TDE) y Granularidad de Columna en PostgreSQL

El almacenamiento de información en el Core Bancario basado en PostgreSQL Enterprise cuenta con dos capas independientes de cifrado en reposo. A nivel de infraestructura física y volúmenes lógicos, se implementa el Cifrado de Datos Transparente (TDE) utilizando el algoritmo estandarizado AES con encadenamiento por bloques de difusión optimizada (XTS-AES-256). Esta capa garantiza que si un dispositivo de estado sólido o disco magnético es sustraído físicamente del centro de datos principal o secundario de Neobank Digital, los bloques lógicos binarios resulten totalmente indecifrables ante lecturas directas en frío.

A nivel de capa de datos y lógica relacional, los campos clasificados como Datos Identificables Directos (DID) y Datos Financieros Operativos (DFO) incorporan cifrado homomórfico y determinista de columna. Esto significa que la base de datos almacena únicamente el criptograma generado y las operaciones de búsqueda o indexación sobre elementos como el NIT o el CUI se ejecutan de manera directa en el dominio cifrado sin requerir que el motor de la base de datos descifre la información en memoria swap o discos temporales. El descifrado en texto plano ocurre exclusivamente en la capa de aplicación interna tras la validación de un token de autorización firmado por el servicio central de IAM.

2.2. Administración de Ciclo de Vida de Llaves en Hardware Criptográfico (HSM)

Todas las llaves maestras de cifrado de datos (KEK - Key Encryption Keys) y llaves de cifrado de datos directas (DEK - Data Encryption Keys) de Neobank Digital residen y se administran exclusivamente dentro de módulos de seguridad de hardware dedicados (**HSM**), los cuales cuentan con la certificación de seguridad federal **FIPS 140-2 Nivel 3**. Las llaves nunca se exportan del HSM ni son accesibles en texto claro para ingenieros, administradores de bases de datos o directivos de la Entidad.

El ciclo de vida de las llaves sigue las políticas estrictas de control resumidas en la siguiente tabla de gobernanza criptográfica:

Tipo de Llave	Algoritmo Base	Ubicación de Almacenamiento	Frecuencia de Rotación	Esquema de Recuperación y Respaldo
Llave Maestra de Cifrado (KEK)	RSA-4096 / ECC Curve P-384	HSM Root FIPS 140-2 Nivel 3 (Aislamiento Físico)	Cada 365 días (Rotación programada por hardware)	Esquema de Secreto Compartido de Shamir (M de N: Requiere presencia física de 3 Custodios).
Llaves de Datos por Columna (DEK)	AES-GCM-256	Almacenamiento Cifrado (Inyectada al inicio por KEK)	Cada 90 días o ante revocación de rol operativo	Re-encryptación automatizada en caliente de las columnas mediante pipeline asíncrono del Core Bancario.
Llaves Efímeras de Sesión Transaccional	ECDHE (Elliptic Curve Diffie-Hellman)	Memoria RAM Volátil Protegida (Secure Enclaves)	Destrucción automática al término de cada llamada API	Ninguno (No persistente). La llave se descarta irrevocablemente al cerrar el socket lógico de red.

CAPÍTULO III: EL PROTOCOLO OPERATIVO Y TECNOLÓGICO DE DERECHOS ARCO

3.1. Arquitectura de Interfaces Digitales para Ejercicio de Derechos

Neobank Digital proporciona de manera obligatoria una sección automatizada y dedicada dentro del menú de configuración de seguridad de su plataforma para que los usuarios puedan ejercer sin intermediación humana inicial sus derechos de Acceso, Rectificación, Cancelación y Oposición (Derechos ARCO). El acceso a esta interfaz requiere un factor de re-autenticación biométrica forzada (FaceID / TouchID / Validación de vectores faciales contra el backend central), garantizando de forma absoluta que la persona que invoca el derecho es efectivamente el titular legítimo de la cuenta y los datos asociados, mitigando ataques de ingeniería social o acceso físico no autorizado al dispositivo móvil.

3.2. Derecho de Acceso: Flujos Técnicos de Generación y Estructura del Payload

Cuando un titular activa el Derecho de Acceso, el microservicio de orquestación de privacidad inicia una consulta distribuida en caliente a través de todos los motores de persistencia de la Entidad (PostgreSQL, clústeres NoSQL, buckets de almacenamiento de documentos y logs de cumplimiento de la IVE). El sistema extrae la totalidad de la información vinculada al UUID del cliente, incluyendo historiales de navegación perimetral, variables analíticas de riesgo de fraude y datos maestros de identidad.

Esta información es compilada en un payload JSON estructurado bajo codificación universal UTF-8. Para asegurar el cumplimiento de la portabilidad, el sistema genera de forma paralela un archivo CSV comprimido dentro de un contenedor ZIP cifrado con una contraseña dinámica que se envía al teléfono móvil verificado del cliente mediante un canal alternativo SMS OTP. El tiempo técnico de respuesta para la puesta a disposición del archivo descargable se fija en un plazo de **cinco (5) días hábiles** contados a partir de la solicitud, quedando el registro de descarga documentado criptográficamente en el ledger inmutable de gobernanza de la Entidad.

3.3. Derecho de Rectificación: Sincronización Distribuidora de Estados

El Derecho de Rectificación permite al usuario corregir inconsistencias, errores o desactualizaciones en sus datos identificables directos e indirectos. Una vez que el usuario modifica un atributo (por ejemplo, cambio de dirección residencial o actualización del pasaporte por renovación legal) y adjunta la documentación digital probatoria en formato PDF con firma electrónica o validez legal, el sistema cambia el estatus del campo afectado a ***MODIFICACIÓN_EN_PROCESO_DE_VALIDACIÓN***.

Este cambio dispara un evento asíncrono en el bus de datos empresarial (Kafka Message Bus) que propaga la actualización a la totalidad de las réplicas de bases de datos, cachés en memoria (Redis clúster) y servicios analíticos de prevención de fraude en un plazo que no excederá de **cuarenta y ocho (48) horas**. Si la rectificación corresponde a

datos críticos incluidos en el formulario IVE, el cambio requiere aprobación explícita de un analista de cumplimiento tras re-verificar la validez de los datos con los servidores centrales de las entidades estatales emisoras (RENAP o SAT).

CAPÍTULO IV: RESTRICCIONES TÉCNICAS Y LEGALES AL DERECHO DE CANCELACIÓN

4.1. Primacía Legal de la Retención Financiera y de la IVE

El Derecho de Cancelación (también conceptualizado bajo estándares internacionales como el "Derecho al Olvido") no opera de manera absoluta dentro del ecosistema financiero de Neobank Digital. Ante la recepción de una solicitud de supresión de datos personales por parte de un usuario, el motor de reglas jurídicas de la plataforma evalúa de manera prioritaria el estatus de la cuenta y las obligaciones normativas impuestas por la legislación de la República de Guatemala. De conformidad con la Ley Contra el Lavado de Dinero u Otros Activos (Decreto 67-2001) y la Ley de Bancos y Grupos Financieros (Decreto 19-2002), la Entidad se encuentra obligada legalmente a conservar los registros de identidad y la trazabilidad financiera completa de sus clientes por un período de ****cinco (5) a diez (10) años**** posteriores al cierre definitivo de la relación comercial.

En consecuencia, si un usuario solicita la cancelación de sus datos, el sistema rechazará la destrucción física inmediata de los registros relacionales y transaccionales primarios. El sistema notificará de manera justificada al interesado fundamentando la negativa en las citadas disposiciones de orden público y leyes de prevención de lavado de dinero de la Intendencia de Verificación Especial. La cancelación se interpretará jurídicamente como la finalización de los tratamientos de datos basados en el consentimiento comercial.

4.2. Protocolo de Bloqueo Técnico de Datos (Data Port Locking)

Para aquellos datos cuya destrucción física inmediata esté legalmente prohibida, el ejercicio del Derecho de Cancelación activa de forma obligatoria el Protocolo de Bloqueo Técnico de Datos (Data Port Locking). El microservicio de persistencia ejecuta un script que remueve el identificador del usuario de todos los índices de búsqueda comerciales, de marketing predictivo y analítica de negocios.

El proceso técnico se compone de las siguientes fases automatizadas:

1. **Aislamiento Lógico:** La fila correspondiente al usuario en la base de datos de producción cambia su bandera a `status: BLOCKED_BY_COMPLIANCE_ARCO`.
2. **Revocación de Permisos:** Las credenciales de acceso de las aplicaciones front-end y microservicios ordinarios pierden todo derecho de lectura sobre estos registros.
3. **Ofuscación de Columnas No Reguladas:** Aquellos datos que no forman parte de las exigencias obligatorias de la IVE o del Código de Comercio (tales como preferencias estéticas dentro de la app, historiales de interacciones con el servicio al cliente y cookies de navegación) se eliminan mediante borrado físico irreversible empleando el método NIST SP 800-88 Rev. 1.

Los datos remanentes bloqueados permanecen en un estado puramente pasivo y cifrado en reposo, quedando a la espera exclusiva del vencimiento de los plazos de retención legal para su purga definitiva.

CAPÍTULO V: DERECHO DE OPOSICIÓN Y MECANISMOS DE EXCLUSIÓN LÓGICA (OPT-OUT)

5.1. Oposición a Tratamientos Secundarios y Elaboración de Perfiles Comerciales

El Derecho de Oposición faculta al usuario para prohibir el uso de sus datos personales para finalidades que no sean estrictamente necesarias para el mantenimiento y ejecución de la relación contractual financiera primaria. Neobank Digital reconoce que la elaboración de perfiles de consumo, la segmentación con fines publicitarios, el envío de ofertas comerciales dirigidas de socios comerciales independientes y el entrenamiento de modelos internos de inteligencia artificial para personalización de interfaces constituyen fines secundarios opcionales.

Cuando el usuario activa el comando de Oposición a través de la interfaz digital, el sistema actualiza de forma síncrona el registro de consentimientos del cliente e inserta una directiva de exclusión lógica (Opt-Out Flag). A partir de ese momento, los motores de ejecución de campañas de marketing digital y los algoritmos de recomendación de productos excluyen automáticamente el UUID del cliente de sus flujos de datos. El ejercicio de este derecho es completamente gratuito y no puede ser utilizado por la Entidad como justificación para degradar la calidad de los servicios core bancarios, alterar los límites transaccionales permitidos o imponer tarifas de manejo de cuenta diferenciadas, resguardando la libertad

de elección del cliente.

5.2. Tiempos de Respuesta y Escalación ante Controversias

Las solicitudes de Derecho de Oposición que no afecten la continuidad operativa de la cuenta bancaria deben ser procesadas y ejecutadas por la plataforma técnica en un plazo máximo de ****veinticuatro (24) horas**** continuas desde su recepción en el backend. El sistema enviará un comprobante digital en formato PDF firmado con la llave del microservicio de privacidad que certifica al usuario la exclusión exitosa de sus datos de los entornos analíticos secundarios.

Si el usuario considera que la Entidad continúa explotando comercialmente sus datos personales de navegación o consumo a pesar de haber ejercido su derecho de oposición, o si se presenta un fallo técnico en las rutinas de exclusión lógica del bus de datos Kafka, el interesado podrá elevar un recurso de apelación interna directo ante la oficina del Encargado de Protección de Datos (DPO) mediante el canal de soporte. El DPO iniciará una auditoría técnica forense sobre los logs de ejecución del sistema y emitirá un dictamen definitivo de remediación en un plazo no mayor a diez (10) días hábiles, garantizando la resolución transparente de controversias relativas a la privacidad.